Propósito del módulo

MÓDULO 5

A07 — Fallos de Autenticación



OWASP Top 10:2025 | Java 17 · Jakarta EE 11

50 diapositivas · Credenciales · Sesiones · Prevención

A07:2025 en OWASP Top 10

A07:2025 — Fallos de Autenticación mantiene la posición #7, igual que en 2021. El nombre se ajustó para reflejar con mayor precisión las 36 CWEs incluidas en la categoría.

OWASP señala que, pese a los beneficios de los marcos de trabajo estandarizados, la categoría ha mantenido su rango. Esto subraya que utilizar un framework no garantiza una configuración correcta.

El riesgo aparece cuando el sistema acepta una identidad incorrecta, permite abuso automatizado o mantiene sesiones y tokens más tiempo o con mayor alcance del previsto.



A07:2025 permanece en el puesto #7.

Qué es una falla de autenticación

OWASP describe la falla cuando un atacante puede engañar al sistema para que reconozca como legítimo a un usuario inválido o incorrecto.

Puede originarse en credenciales débiles, validación incorrecta, ausencia de MFA, mecanismos de recuperación ineficaces, intentos automatizados sin limitar o sesiones que no se invalidan correctamente.

El análisis debe cubrir el proceso completo: alta, inicio de sesión, autenticación adicional, recuperación, cambio de contraseña, renovación de sesión y cierre de sesión.



La autenticación debe ser robusta durante todo su ciclo de vida.

Autenticación no es autorización

La autenticación verifica una identidad o factor de autenticación. La autorización evalúa si esa identidad puede realizar una acción sobre un recurso concreto.

Un inicio de sesión correcto no debe habilitar automáticamente todas las operaciones. Después de autenticar, cada solicitud sensible debe aplicar los permisos y reglas correspondientes.

En el caso hipotético del curso, autenticar a un operador no significa que pueda aprobar una transferencia, administrar beneficiarios o consultar cuentas ajenas.



Identidad confirmada ≠ permiso ilimitado.

Superficies del proceso de autenticación

Las superficies incluyen registro, inicio de sesión, cambio y recuperación de contraseña, autenticación multifactor, APIs, federación de identidad y gestión de sesiones.

También deben revisarse integraciones de SSO, tokens, certificados, aplicaciones móviles, dispositivos recordados y canales alternativos de autenticación.

Un control fuerte en la pantalla principal puede ser eludido si existe una ruta secundaria, un endpoint legado o un flujo de recuperación menos protegido.



Revisar rutas principales y alternativas.

Credenciales predeterminadas y codificadas

OWASP considera riesgoso permitir contraseñas predeterminadas, débiles o muy conocidas, por ejemplo combinaciones administrativas predecibles.

También mapea el uso de contraseñas o credenciales codificadas de forma rígida en archivos o código. Una credencial incluida en un artefacto puede filtrarse por repositorios, paquetes o respaldos.

No distribuir ni desplegar aplicaciones con credenciales predeterminadas, especialmente para administradores. La inicialización debe exigir configuración segura y credenciales únicas.



CWE-259 y CWE-798: contraseñas y credenciales hard-coded.

Contraseñas débiles y conocidas

Una contraseña débil puede ser predecible, reutilizada o estar incluida en listas de credenciales comunes. Las reglas de complejidad por sí solas no garantizan resistencia frente a ataques.

OWASP recomienda comprobar contraseñas nuevas o modificadas contra listas de las 10,000 peores contraseñas y contra listas de credenciales conocidas como comprometidas.

La comprobación debe realizarse durante el alta y el cambio de contraseña, sin revelar al usuario si una cuenta existente utiliza una contraseña específica.



Rechazar secretos triviales y comprometidos antes de almacenarlos.

Longitud, complejidad y políticas

La fuente OWASP A07:2025 recomienda alinear longitud, complejidad y políticas de rotación con las directrices NIST 800-63b citadas en el documento u otras políticas modernas basadas en evidencia.

El material indica no obligar a las personas a rotar contraseñas salvo que se sospeche una vulneración. Si se sospecha compromiso, debe forzarse el restablecimiento de inmediato.

Evite políticas que empujen a cambiar un carácter periódicamente o a reutilizar patrones. La política debe favorecer secretos robustos, únicos y gestionables.



Rotación por evidencia de compromiso, no por calendario arbitrario.

Gestores de contraseñas

OWASP recomienda fomentar y habilitar el uso de gestores de contraseñas para ayudar a las personas a tomar mejores decisiones.

Un gestor facilita generar y mantener contraseñas largas y únicas, reduciendo la reutilización entre servicios. La organización debe evitar interfaces que bloqueen innecesariamente el autocompletado o el pegado.

El gestor no elimina la necesidad de MFA, protección del dispositivo y recuperación segura. Forma parte de una estrategia de credenciales, no es un control aislado.



Facilitar contraseñas únicas y difíciles de adivinar.

Almacenamiento seguro de contraseñas

OWASP identifica como señales de falla el almacenamiento de contraseñas en texto claro, cifradas de forma reversible o protegidas con hash débil.

El almacenamiento de contraseñas debe utilizar una función de derivación diseñada para contraseñas, con sal única y parámetros adecuados. No debe confundirse con cifrar datos que luego se necesitan recuperar.

El detalle criptográfico se relaciona con A04:2025 — Fallas Criptográficas. En este módulo se verifica que la autenticación no dependa de secretos recuperables o hashes débiles.



Conectar A07 con A04: proteger el secreto almacenado.

Verificación de contraseña en el servidor

La comprobación de credenciales debe ejecutarse en el servidor. El cliente no debe decidir que una contraseña es válida ni conservar la contraseña en almacenamiento local persistente.

El servidor compara el secreto recibido con el verificador almacenado usando la función adecuada y aplica controles de abuso. Las respuestas deben evitar revelar si falló el usuario o la contraseña.

Las trazas no deben registrar contraseñas, códigos MFA, tokens de recuperación ni identificadores de sesión completos. La observabilidad debe preservar la confidencialidad.



El secreto nunca debe aparecer en logs ni mensajes de error.

Credential stuffing

El relleno de credenciales utiliza listas de combinaciones de usuario y contraseña obtenidas previamente, por ejemplo mediante filtraciones en otros servicios.

El ataque aprovecha la reutilización de contraseñas. Si la aplicación no limita automatización ni incorpora controles adicionales, puede convertirse en un oráculo para comprobar cuáles credenciales siguen siendo válidas.

OWASP recomienda MFA siempre que sea posible, controles contra automatización y alertas ante patrones de credential stuffing.



Credenciales reutilizadas + automatización = acceso no autorizado.

Password spraying e intentos híbridos

OWASP describe ataques de contraseñas híbridos o password spray que prueban variaciones o incrementos de credenciales comprometidas, aprovechando patrones humanos.

Ejemplos del documento incluyen cambiar un año o un número al final de una contraseña conocida. Esta estrategia puede eludir defensas centradas en detectar muchas contraseñas distintas contra una sola cuenta.

Las defensas deben observar patrones por cuenta, origen, dispositivo y ventana temporal, evitando depender de una sola señal o de umbrales fáciles de evadir.



Detectar patrones distribuidos, no solo fallos consecutivos por cuenta.

Fuerza bruta y automatización

La fuerza bruta prueba múltiples combinaciones hasta encontrar una válida. Los scripts pueden distribuir solicitudes y variar su ritmo para evadir controles simples.

OWASP identifica como falla permitir ataques automatizados que no se bloquean rápidamente. La defensa debe combinar límites, demoras incrementales, MFA, monitoreo y respuestas cuidadosas.

Un bloqueo rígido por cuenta puede facilitar denegación de servicio contra usuarios legítimos. El control debe equilibrar protección, disponibilidad y posibilidad de recuperación.



Reducir automatización sin convertir el control en DoS.

Limitación de intentos y demoras

OWASP recomienda limitar o retrasar de forma incremental los intentos fallidos de inicio de sesión. La defensa debe registrar fallos y alertar ante sospecha de credential stuffing, fuerza bruta u otros ataques.

Los límites pueden considerar cuenta, dirección de origen, dispositivo, red y señales de riesgo. La aplicación debe evitar que un atacante bloquee indefinidamente la cuenta de otra persona.

Defina umbrales, recuperación, excepciones y monitoreo con base en el riesgo y el patrón de uso. No dependa de una única regla estática.



Rate limiting + demora incremental + alertas.

Autenticación multifactor (MFA)

OWASP recomienda implementar y aplicar MFA siempre que sea posible para prevenir ataques automatizados de credential stuffing, fuerza bruta y reutilización de credenciales robadas.

MFA requiere más de un factor independiente. El diseño debe especificar cuándo se exige, cómo se registra un factor, cómo se recupera el acceso y cómo se revoca un factor perdido o comprometido.

La MFA no elimina todo riesgo: puede existir phishing, fatiga de aprobación, recuperación débil o alternativas de menor seguridad. Deben revisarse los flujos completos.



MFA eficaz en los flujos de alto impacto.

Recuperación de credenciales

OWASP considera débiles los procesos de recuperación que dependen de preguntas de seguridad basadas en conocimiento, porque no pueden hacerse seguros de forma confiable.

El flujo debe protegerse contra enumeración de cuentas, automatización y toma de control. Debe utilizar mecanismos de verificación apropiados, limitar intentos y notificar eventos relevantes.

El cambio o restablecimiento de contraseña debe invalidar credenciales o sesiones que ya no deban ser válidas y requerir verificación adecuada del solicitante.



Recuperación segura: mismo rigor que el inicio de sesión.

Cambio de contraseña y eventos de riesgo

El cambio de contraseña debe requerir una verificación apropiada y protegerse contra solicitudes no autorizadas. OWASP incluye CWE-620, cambio de contraseña no verificado.

Ante sospecha de compromiso, debe forzarse el restablecimiento de inmediato. La aplicación también debe revisar sesiones activas, tokens y métodos de recuperación asociados.

Notifique al usuario cambios importantes por un canal apropiado, sin incluir secretos. Registre el evento y facilite una respuesta si el cambio no fue autorizado.



Un cambio de contraseña puede requerir revocar sesiones y tokens.

Qué representa una sesión

Una sesión permite mantener continuidad entre solicitudes después de autenticar al usuario. El identificador de sesión vincula las solicitudes posteriores con un contexto autenticado administrado por el servidor.

El identificador debe ser impredecible, tener alta entropía y tratarse como un secreto portador: quien lo obtiene puede intentar utilizar la sesión asociada.

Una sesión segura requiere creación, almacenamiento, transporte, renovación, expiración y destrucción adecuados. Cada etapa debe estar definida y probada.



El ID de sesión es un secreto temporal de alto valor.

Identificadores de sesión expuestos

OWASP identifica como falla exponer el identificador de sesión en la URL, en un campo oculto u otra ubicación insegura accesible para el cliente.

Las URLs pueden terminar en historial, registros de servidor, encabezados Referer, capturas o herramientas de monitoreo. Un campo oculto también puede leerse o modificarse desde el cliente.

El material recomienda almacenar el identificador de forma segura en una cookie segura y no incluirlo en la URL.



Evitar IDs de sesión en URL y campos ocultos.

Regeneración del ID después del login

OWASP indica que el gestor debe generar un nuevo ID de sesión aleatorio con alta entropía después del inicio de sesión exitoso.

Reutilizar el mismo identificador antes y después de autenticar permite escenarios de fijación de sesión: un atacante puede intentar que la víctima use un identificador conocido previamente.

La regeneración debe preservar solo el estado legítimo necesario y descartar el identificador anterior. Debe aplicarse también cuando cambian privilegios o se eleva el nivel de autenticación.



Regenerar ID tras autenticación y cambios de privilegio.

Fijación de sesión

La fijación de sesión (CWE-384) ocurre cuando la aplicación no cambia el identificador al autenticar o elevar privilegios, permitiendo que un ID controlado o conocido conserve valor.

El riesgo aumenta si el identificador puede imponerse o exponerse antes del inicio de sesión y después se reutiliza para una sesión autenticada.

La defensa es generar un nuevo ID impredecible después del login, invalidar el anterior y verificar el comportamiento con pruebas automatizadas.



CWE-384 · regenerar e invalidar el identificador anterior.

Expiración por inactividad y absoluta

OWASP recomienda invalidar sesiones tras el cierre de sesión, por inactividad y tras tiempos de espera absolutos.

El timeout por inactividad limita cuánto tiempo puede permanecer activa una sesión sin uso. El timeout absoluto establece un límite total, incluso si hay actividad continua.

Los valores deben responder al riesgo, sensibilidad de las operaciones y contexto de uso. No deben depender exclusivamente del cierre de pestaña o de una acción del navegador.



Timeout inactivo + límite absoluto.

Cierre de sesión efectivo

Cerrar una pestaña no equivale a cerrar sesión. OWASP presenta el caso de una persona que usa un equipo público, cierra el navegador y deja una sesión activa.

El cierre de sesión debe invalidar la sesión del lado servidor y eliminar o expirar la cookie correspondiente. Si existen tokens o sesiones federadas, debe definirse su revocación o cierre coordinado.

El sistema debe confirmar el cierre de manera clara y evitar que el botón solo oculte la interfaz mientras la sesión sigue siendo válida.



Logout debe invalidar el estado en el servidor.

SSO y cierre de sesión único

OWASP describe el riesgo de SSO cuando una persona cree haber cerrado sesión, pero otras aplicaciones integradas mantienen una sesión autenticada.

El cierre local de una aplicación no necesariamente termina la sesión en el proveedor de identidad ni en otros servicios. El diseño debe definir qué significa cerrar sesión en cada componente.

Cuando aplique, implemente y pruebe el mecanismo de Single Logout y la invalidación de sesiones o tokens relevantes. Documente límites y comportamientos cuando un proveedor no responda.



El cierre debe cubrir el alcance real de la sesión federada.

Gestor de sesiones integrado

OWASP recomienda utilizar un gestor de sesiones integrado, seguro y del lado servidor, en lugar de inventar un mecanismo propio.

Un gestor probado reduce errores en generación de IDs, cookies, expiración y renovación. La aplicación debe configurar correctamente el mecanismo y evitar sobrescribirlo con lógica personalizada innecesaria.

Cuando sea posible, OWASP recomienda transferir el riesgo a un sistema establecido y confiable para autenticación, identidad y gestión de sesiones.



Preferir mecanismos establecidos y bien probados.

Monitoreo y alertamiento

Registre fallos de autenticación y alerte a administradores cuando se detecten o sospechen ataques de credential stuffing, fuerza bruta u otros patrones automatizados.

Los eventos útiles pueden incluir identificador interno de cuenta, fecha, resultado, origen aproximado, dispositivo o señal de riesgo, evitando registrar contraseñas, tokens completos o datos innecesarios.

El monitoreo debe ayudar a detectar patrones distribuidos y permitir investigación. Los umbrales, retención y acceso a logs deben ser coherentes con la política de seguridad.



Telemetría útil sin almacenar secretos.

Errores y mensajes seguros

Los mensajes de autenticación deben evitar revelar si una cuenta existe, está bloqueada o tiene una contraseña incorrecta cuando esa diferencia facilita enumeración.

Un mensaje genérico no basta si el código HTTP, el tamaño de respuesta o el tiempo de procesamiento revelan información. Compare respuestas para cuentas existentes y no existentes.

Los errores técnicos deben registrarse de forma protegida y no exponerse al usuario. Nunca incluya contraseñas, códigos de un solo uso o tokens en mensajes.



Respuesta genérica y comportamiento consistente.

Laboratorio 1 · revisar el flujo de login

Inspeccione un endpoint de autenticación de ejemplo. Trace la entrada de usuario y contraseña, el verificador almacenado, el resultado, los mensajes de error y los registros generados.

Identifique si hay credenciales predeterminadas, almacenamiento inadecuado, respuestas que permiten enumeración, ausencia de límites o secretos que aparecen en logs.

Proponga correcciones y pruebas automatizadas. Use cuentas y datos sintéticos, sin realizar pruebas contra sistemas ajenos ni credenciales reales.



Entregable: mapa de flujo y lista de hallazgos.

Laboratorio 2 · Implementar alertamiento

En un entorno local, implementar un Sistema de alertamiento para que despues de 5 o más intentos de inicio de session fallidos, se envíe un correo electrónico.



Entregable: evidencia de regeneración, expiración e invalidación.

Checklist de aseguramiento A07

Credenciales: ¿se eliminan valores predeterminados y hard-coded? ¿Se verifican contraseñas débiles o comprometidas? ¿El almacenamiento evita texto claro y hash débil? ¿Se habilita MFA eficaz?

Autenticación: ¿se limita la automatización? ¿Se evitan enumeración y recuperación débil? ¿Se registran fallos y se generan alertas sin exponer secretos?

Sesiones: ¿se genera un nuevo ID tras login? ¿Se almacena en cookie segura? ¿Se invalida en logout, inactividad y timeout absoluto? ¿Se valida audiencia, emisor y alcance de tokens?



Cada respuesta debe acompañarse de evidencia técnica.